



SMART-CONTRACT SECURITY ASSESSMENT

AEGENT V2 Core Smart-Contract Security Assessment

Core Review / Control-Oriented Profile

Author and issuer: AEGENT Security Review Team

Assessment date: 2026-07-29

Target environment: BNB Chain mainnet deployment candidate

Assessment type: point-in-time source review of an uncommitted working-tree snapshot

FINAL DISPOSITION remediation required before mainnet

This report is authored and issued by the AEGENT Security Review Team. It is not authored, reviewed, endorsed, signed, certified, or issued by OpenZeppelin, CertiK, or SlowMist. No third-party logo, signature, certificate, report number, or issuance claim is used. The section order is only informed by public control-oriented security-report conventions.

Contents

Executive summary

Scope and source identity

System overview

- Components

- Principal trust assumptions

- Security properties observed

Methodology

Finding summary

Detailed findings

- MED-01 — Manual-review threshold can be bypassed by splitting redemptions

- MED-02 — Purchases can increase refund liability without enforced reserve collateral

- MED-03 — Freshness-only oracle validation lacks bounds and deviation circuit breakers

- LOW-01 — Fixed UTC daily buckets permit near-two-times throughput at a boundary

- INFO-01 — Privileged controls do not enforce a multisig or general timelock

- INFO-02 — Immutable recipients and narrow recovery paths create asset-liveness risk

- INFO-03 — Settlement events omit configuration evidence needed for complete reconstruction

Test, coverage, and static-analysis evidence

- Fresh test result

- Fresh coverage

- Fresh Slither result

Limitations

Required remediation and retest order

Conclusion

Executive summary

The review covered the AEGENT V2 market registry, sale-proceeds vault, purchase endpoint, redemption endpoint, and the project-owned interfaces they consume. Manual review was supported by a fresh Hardhat test run, Solidity coverage, Slither static analysis, and line-by-line review of custody, pricing, accounting, authorization, replay resistance, and state-transition invariants.

No Critical or High-severity issue was identified in the reviewed snapshot. Three Medium, one Low, and three Informational findings remain open:

Severity	Open	Closed
Critical	0	0
High	0	0
Medium	3	0
Low	1	0
Informational	3	0

The absence of a Critical or High finding is not a guarantee of defect-free code. The review found meaningful controls against reentrancy, direct replay, cross-phase price replay, double refunds, claim reuse, unauthorized withdrawals, and arithmetic truncation abuse. However, the open Medium findings affect operational risk controls, refund-reserve assurance, and oracle anomaly handling. Mainnet deployment should remain blocked until they are remediated and retested.

Scope and source identity

The controlling source is the frozen copy under [source-snapshot/](#). Repository context recorded by the project handoff was [cae20adb0497c46906e36cb98bcd3d19232c98b](#); that commit is contextual only and is **not** asserted to contain this working-tree snapshot.

File	SHA-256
contracts/AagentMarketRegistry.sol	1e0fc93396402b19d085bbfc25d03be53540e847039dd768c6d47bf379f49aa9
contracts/AagentSaleProceedsVault.sol	983af93be4bb1fcbe2809c9fb01baea34a7bae0ddf12caf05933c5450842cc34
contracts/AagentSwapV2.sol	2b53552a367b757cc31721d31cb2e889dc9391afc293a4cac0b2590332fb515f
contracts/AagentRedemptionV2.sol	2424be9e3141b055d0a27a7b12ab6fc3918d758ddbedc9201ebc454dd467fcc6
contracts/interfaces/IAagentMarketRegistry.sol	fb7b9a35bef353c3c0a5e882da595294b9dad8d81cedada1207bbfe7bb02309
contracts/interfaces/IAagentPurchaseReceiptSource.sol	52abd846c87734040bfb375177186bff6d8b56f9b23ddbeeb8a7a4f4c3d5badb
contracts/interfaces/IAagentRedemptionEndpoint.sol	92620d9cc1fec26c42b4d4d293447d4faf9d83aab05a065d7484eff299d89eab

File	SHA-256
contracts/interfaces/IAgentRegistryBound.sol	bf53c7606cbc5853a74710c9fa31dfd256a31283eedaf7ede01e213b0f12bc84
contracts/interfaces/IAgentSaleProceedsVault.sol	eb1005d38941efc7dfd9e8c961eb5a4df10f9a43f630330495dd82b73854c974
contracts/interfaces/IAggregatorV3.sol	2dc0d69856b9cf3579d866c1da3bb9baff2fe505d9702001fcddc47e319a2b7e

Mocks, deployment scripts, frontends, APIs, wallet code, production configuration, operational key custody, and deployed bytecode were not part of the audited source scope. Tests and deployment-script tests were used as supporting evidence only.

System overview

Components

- [AgentMarketRegistry](#) is the authoritative schedule, phase, market-mode, limited-window, endpoint-binding, and configuration-version source.
- [AgentSaleProceedsVault](#) locks native and supported stablecoin sale proceeds until [saleEnd](#), then releases them to an immutable beneficiary.
- [AgentSwapV2](#) accepts BNB, USDT, or USDC, calculates USD value using Chainlink-compatible feeds, applies the active fixed phase rate, records wallet purchase receipts, escrows AGNT in the redemption endpoint, and forwards consideration to the vault.
- [AgentRedemptionV2](#) provides presale cost-basis refunds in [REDEMPTION_ONLY](#), post-launch AGNT redemption using a delayed owner-proposed rate, purchased-AGNT claims at sale end, reserve locking, daily limits, and one-time execution nonces.

Principal trust assumptions

- The owner account acts honestly and remains secure.
- Registry-bound endpoint addresses are deployed from the reviewed code and configured correctly.
- AGNT, USDT, and USDC conform to the assumed ERC-20 behavior.
- Oracle addresses are official feeds for the target chain and remain live and economically representative.
- The immutable vault beneficiary can receive native BNB and supported tokens.
- Off-chain clients set meaningful [minAgntOut](#) / [minUsdtOut](#) values and enforce the intended network and address configuration.

Security properties observed

- State-changing purchase and redemption paths use [nonReentrant](#).
- Token movement uses [SafeERC20](#) and exact before/after balance checks.
- Purchases are bound to expected phase, mode, limited-window ID, configuration version, minimum output, and a maximum five-minute deadline.

- Redemptions are bound to expected phase, mode, configuration version, rate version, minimum output, deadline, and a per-wallet execution nonce.
- Presale refunds use wallet purchase cost basis rather than the current advertised phase rate.
- Purchased AGNT claims are cleared before transfer and cannot be repeated.
- Reserve and AGNT withdrawal calculations preserve recorded presale liabilities and unclaimed entitlements.
- Ownership renunciation is disabled, avoiding accidental permanent loss of required controls.
- Solidity [0.8.24](#), checked arithmetic, and [Math.mulDiv](#) reduce overflow and precision-loss risk.

Methodology

The assessment applied:

1. Manual review of authorization, custody, external calls, checks-effects-interactions, accounting, rounding, oracle use, time boundaries, replay protection, emergency controls, and event evidence.
2. Invariant review across Registry → Swap → Vault → Redemption state transitions.
3. Fresh Hardhat execution: **42 passing tests**.
4. Fresh [solidity-coverage 0.8.17](#) instrumentation.
5. Fresh [Slither 0.11.5](#) analysis with dependency-only results excluded and manual triage of every project result.
6. Source-to-snapshot SHA-256 comparison.

Severity reflects practical impact and exploitability in the stated trust model:

- **Critical:** direct or systemic loss with broad, reliable exploitation.
- **High:** material loss or permanent protocol failure under realistic conditions.
- **Medium:** meaningful financial, control, or availability impact with prerequisites or bounded scope.
- **Low:** limited impact, edge-condition control weakness, or defense-in-depth gap.
- **Informational:** governance, observability, maintainability, or deployment hardening.

Finding summary

ID	Severity	Title	Status
MED-01	Medium	Manual-review threshold can be bypassed by splitting redemptions	Open; no retest
MED-02	Medium	Purchases can increase refund liability without enforced reserve collateral	Open; no retest
MED-03	Medium	Freshness-only oracle validation lacks bounds and deviation circuit breakers	Open; no retest

ID	Severity	Title	Status
LOW-01	Low	Fixed UTC daily buckets permit near-two-times throughput at a boundary	Open; no retest
INFO-01	Informational	Privileged controls do not enforce a multisig or general timelock	Open; no retest
INFO-02	Informational	Immutable recipients and narrow recovery paths create asset-liveness risk	Open; no retest
INFO-03	Informational	Settlement events omit configuration evidence needed for complete reconstruction	Open; no retest

Detailed findings

MED-01 — Manual-review threshold can be bypassed by splitting redemptions

Status: Open; no remediation retest

Affected code: [`AagentRedemptionV2.sol:L190-L227`](#), [`AagentRedemptionV2.sol:L694-L731`](#)

Test evidence: [`AagentRedemptionV2.test.cjs:L454-L494`](#)

The constructor allows `manualReviewThresholdUsdt` to be less than or equal to the wallet daily limit. `_validateRedemption` compares the review threshold only with the current transaction's `grossUsdt`. The cumulative wallet total is checked separately against `dailyWalletUsdtLimit`.

The test demonstrates the exact behavior: a redemption whose gross value is 201 USDT is rejected, while two 200 USDT redemptions both succeed. The third transaction is rejected only after the wallet daily total would exceed 400 USDT.

Impact: A user can avoid the intended manual-review workflow while redeeming up to the wallet and global daily limits. This does not bypass cost-basis entitlement, AGNT collection rules, reserve checks, or daily caps, but it weakens a stated AML/risk-control boundary.

Recommendation: Apply the review threshold to the cumulative rolling or daily wallet amount, or require a separately authorized `redeemReviewed` path containing a reviewer-signed allowance, wallet, maximum amount, nonce, and expiry. Add tests proving that split transactions cannot bypass the same review decision.

MED-02 — Purchases can increase refund liability without enforced reserve collateral

Status: Open; no remediation retest

Affected code: [`AagentMarketRegistry.sol:L186-L227`](#), [`AagentSwapV2.sol:L249-L289`](#),
[`AagentSwapV2.sol:L358-L380`](#), [`AagentRedemptionV2.sol:L522-L553`](#),
[`AagentSaleProceedsVault.sol:L69-L100`](#)

Test evidence: [`AagentRedemptionV2.test.cjs:L240-L274`](#), [`AagentV2Integration.test.cjs:L98-L107`](#)

`purchaseTerms()` validates schedule, mode, limited-window state, and endpoint compatibility, but it does not require the redemption reserve to cover refund liability before enabling a purchase. Both

native and stablecoin purchase paths accept consideration and increase wallet purchase receipts without checking projected reserve coverage.

`AgentRedemptionV2.isOperational()` correctly fails closed when presale liabilities are underfunded, but this check is applied to redemption availability rather than purchase admission. Sale consideration is held in `AgentSaleProceedsVault` until `saleEnd`; it is not automatically reusable as the USDT redemption reserve.

The underfunding test proves that refunds fail closed when the reserve is inadequate. The end-to-end integration test pre-funds the reserve manually before purchases, confirming that current safety depends on an external operational action rather than an enforced purchase invariant.

Impact: The system can accept a valid purchase and create a wallet refund entitlement while the corresponding redemption reserve is insufficient. Refunds remain unavailable until an external reserve top-up, creating a bounded solvency and availability gap even though purchased AGNT claims remain recorded.

Recommendation: Enforce projected reserve coverage during every purchase or fully pre-lock the maximum refund liability before opening sales. A purchase should revert if `reserveAfter / liabilityAfter` falls below the configured requirement. Add tests that attempt BNB, USDT, and USDC purchases against an underfunded reserve and prove atomic rejection.

MED-03 — Freshness-only oracle validation lacks bounds and deviation circuit breakers

Status: Open; no remediation retest

Affected code: ``AagentSwapV2.sol:L165-L167``, ``AagentSwapV2.sol:L552-L618``

Test evidence: ``AagentSwapV2.test.cjs:L424-L468``

The oracle adapter verifies a positive answer, a nonzero and nonfuture timestamp, completed round ordering, and a configurable maximum age. The configured maximum is bounded only by six hours and applies uniformly. There is no per-feed heartbeat, absolute price bound, deviation check, secondary-source comparison, or automatic pause.

Stablecoin values are capped at one dollar on the upside and can decrease when a fresh feed reports a depeg. This is useful, but it does not protect against a feed remaining near one dollar during a fast depeg inside the allowed age. BNB has no absolute or deviation bound, so an anomalously high but technically fresh answer can overvalue BNB and release excess AGNT up to inventory and sale caps.

Existing tests cover a fresh 0.80 USDT price and prices older than the configured age. They do not cover extreme but fresh answers, feed-heartbeat mismatch, or large deviations between consecutive rounds.

Impact: During feed malfunction, rapid market movement, or a stale-within-age interval, the protocol can quote economically invalid output. Depending on direction, the protocol can over-distribute AGNT or a buyer can receive materially less output unless client slippage protection is strict.

Recommendation: Configure a verified feed address and heartbeat per asset; enforce conservative min/max prices; reject deviations beyond a bounded percentage from the prior accepted observation or a secondary source; add a stablecoin depeg floor; and automatically move the market to `PAUSED` when a circuit breaker triggers. Test extreme fresh values and fast-move scenarios.

LOW-01 — Fixed UTC daily buckets permit near-two-times throughput at a boundary

Status: Open; no remediation retest

Affected code: [`AagentRedemptionV2.sol:L713-L731`](#)

Daily limits are indexed by `block.timestamp / 1 days`. A wallet can consume its full daily limit immediately before the UTC bucket changes and consume the next bucket immediately after the change.

Impact: A wallet or the system as a whole can process almost twice the nominal daily limit in a very short real-time interval. Entitlement and reserve requirements still apply, so the issue is bounded.

Recommendation: Use a rolling 24-hour window, a token-bucket limiter, or an epoch scheme with explicit carry rules. If fixed UTC buckets are retained, size limits for the worst-case two-bucket burst and document that behavior.

INFO-01 — Privileged controls do not enforce a multisig or general timelock

Status: Open; no remediation retest

Affected code: [`AagentMarketRegistry.sol:L96-L162`](#), [`AagentSwapV2.sol:L339-L355`](#), [`AagentRedemptionV2.sol:L426-L516`](#)

The owner can change market modes and limited-window parameters and can withdraw eligible inventory or reserves. The post-launch redemption rate has a one-day proposal delay, and ownership uses two-step transfer, but the contracts do not enforce a multisig or a general-purpose timelock.

Recommendation: Assign ownership to a documented multisig, route material configuration changes through a timelock, separate emergency pause authority from treasury authority, and publish role/address monitoring. Validate these controls on-chain before mainnet activation.

INFO-02 — Immutable recipients and narrow recovery paths create asset-liveness risk

Status: Open; no remediation retest

Affected code: [`AagentSaleProceedsVault.sol:L30-L93`](#), [`AagentSwapV2.sol:L671-L672`](#), [`AagentRedemptionV2.sol:L895-L897`](#)

The vault beneficiary is immutable. Native release always calls that beneficiary, so a beneficiary contract that rejects BNB can lock native proceeds. `releaseToken` supports only USDT and USDC; unrelated tokens sent to the vault cannot be recovered. Swap and Redemption reject direct native transfers, but native currency can still be forced to a contract and has no recovery path.

Recommendation: Require a beneficiary with tested payable behavior and operational continuity. Consider a constrained, timelocked recovery function that excludes protected AGNT/USDT/USDC liabilities, or explicitly accept and document the irrecoverability model.

INFO-03 — Settlement events omit configuration evidence needed for complete reconstruction

Status: Open; no remediation retest

Affected code: [`AagentSwapV2.sol:L81-L90`](#), [`AagentRedemptionV2.sol:L122-L133`](#)

`PurchaseSettled` does not include the active market mode or `configVersion`. `RedemptionSettled` includes mode and execution nonce but omits `configVersion`, `rateVersion`, and whether presale cost basis was used.

Impact: Indexers can infer some context from block-state calls, but they cannot reconstruct every settlement's governing configuration solely from the event stream. This weakens forensic and accounting evidence without changing settlement correctness.

Recommendation: Emit the omitted fields or add a compact configuration digest to both settlement events. Add event-argument tests and document the indexing schema.

Test, coverage, and static-analysis evidence

Fresh test result

- Command: `npm.cmd test`
- Result: **42 passing, 0 failing**
- New snapshot-specific evidence includes the redemption execution-nonce test.

Fresh coverage

Scope	Statements	Branches	Functions	Lines
All instrumented files	89.32% (301/337)	56.81% (242/426)	77.50% (62/80)	78.67% (472/600)
Four core contracts	89.67% (295/329)	56.40% (238/422)	85.07% (57/67)	79.72% (460/577)
Market Registry	92.45% (49/53)	65.00% (52/80)	100% (12/12)	90.22% (83/92)
Redemption V2	96.20% (152/158)	51.09% (94/184)	92.31% (24/26)	80.59% (220/273)
Sale Proceeds Vault	70.00% (14/20)	50.00% (16/32)	60.00% (3/5)	65.63% (21/32)
Swap V2	81.63% (80/98)	60.32% (76/126)	75.00% (18/24)	75.56% (136/180)

Coverage is not proof of absence of defects. Instrumentation inflates the branch denominator, and the uncovered withdrawal, failure, oracle-extreme, recovery, and boundary paths require additional tests.

Fresh Slither result

Slither completed successfully and emitted **55 raw detector entries**: 24 Medium, 27 Low, and 4 Informational by detector classification. These are tool alerts, not the accepted audit finding count.

Manual triage determined:

- strict-equality alerts are predominantly intended zero, enum, sentinel, and exact-entitlement checks;
- uninitialized locals rely on Solidity's zero initialization and guarded assignments;

- timestamp alerts mostly describe intentional schedules and deadlines; the actionable boundary issue is LOW-01;
- `locked-ether` reflects rejected direct transfers plus forced-native recovery risk, captured in INFO-02;
- ignored `startedAt` is nonsecurity-relevant because `updatedAt` and round ordering are checked;
- the mock-only zero-address alert is outside production scope;
- the vault event-after-call alert does not expose repeatable theft because the full balance is sent to a fixed recipient, but beneficiary liveness remains relevant;
- high cyclomatic complexity in `_validateRedemption` is a maintainability and testability warning;
- low-level calls are restricted to the configured vault/beneficiary flows.

The raw reports and canonical hashes are recorded in `EVIDENCE_MANIFEST.md`.

Limitations

- This was an AEGENT-authored review, not an independent third-party certification.
- The source was an uncommitted working-tree snapshot. Any byte change invalidates the conclusion until compared and retested.
- No deployed mainnet address, verified bytecode, constructor parameters, ownership transfer, multisig, timelock, oracle-address registry, reserve funding, or transaction receipt was supplied for this assessment.
- No fuzzing campaign, invariant engine, symbolic execution, formal proof, economic simulation, oracle-outage drill, or production key-compromise exercise was completed.
- External ERC-20 and oracle implementations were assumed to match their interfaces.
- Static-analysis severity is heuristic and was manually triaged.
- The isolated coverage tool has a test-only dependency tree and is not part of the production runtime.

Required remediation and retest order

1. Enforce reserve collateral before purchase admission (MED-02).
2. Add oracle bounds, heartbeat-specific age limits, deviation protection, and pause behavior (MED-03).
3. Make manual-review control cumulative or signature-authorized (MED-01).
4. Decide and implement rolling-window limits or explicitly accept UTC burst behavior (LOW-01).
5. Deploy ownership through multisig/timelock controls and verify roles.
6. Resolve or accept recovery and event-evidence gaps.
7. Add regression tests, rerun compilation/tests/coverage/Slither, and perform line-by-line remediation review on the final byte-identical snapshot.

Conclusion

The reviewed snapshot contains multiple strong accounting and replay controls and no identified Critical or High-severity issue. The three open Medium findings still create unacceptable mainnet assurance gaps.

Final disposition: remediation required before mainnet.